

# Action Plan



|                                                |          |
|------------------------------------------------|----------|
| <b>Summary of Audit Report.....</b>            | <b>2</b> |
| <b>Eight Prioritized Vulnerabilities .....</b> | <b>2</b> |
| Vulnerability #1 .....                         | 2        |
| Vulnerability #2 .....                         | 2        |
| Vulnerability #3 .....                         | 3        |
| Vulnerability #4 .....                         | 3        |
| Vulnerability #5 .....                         | 4        |
| Vulnerability #6 .....                         | 4        |
| Vulnerability #7 .....                         | 5        |
| Vulnerability #8 .....                         | 5        |
| <b>Conclusion .....</b>                        | <b>6</b> |

## Summary of Audit Report

The recent Active Directory audit at OpenPharma identified 14 security vulnerabilities, impacting data integrity, compliance, and operational security. Among these, eight critical vulnerabilities have been prioritized for immediate remediation. The selection was based on the severity (CVSS score), business impact, and remediation feasibility. Addressing these vulnerabilities will enhance network security, regulatory compliance, and protection of intellectual property.

## Eight Prioritized Vulnerabilities

We have identified 14 vulnerabilities in the audit report, but we only have time to correct 8. The vulnerability 'Outdated Operating System' is already required. Pick and prioritize the other 7, propose remediation actions, estimate the time and effort needed, and explain/justify your choices.

### Vulnerability #1

- **Title:** Outdated Operating Systems
  - **Priority:** 1
  - **Remediation action :**
    - Upgrade outdated servers to Windows Server 2019 or later.
    - Apply the latest security patches on all machines.
    - Isolate outdated systems that cannot be upgraded immediately and apply strict access controls.
  - **Justification and explanation :**
    - Outdated systems expose OpenPharma to known exploits and increase the risk of data breaches and operational disruptions. Since this vulnerability is pre-selected, addressing it ensures continued regulatory compliance and business continuity.
- 

### Vulnerability #2

- **Title:** Group Policy Preferences (GPP) Passwords
- **Priority:** 2
- **Remediation action :**
  - Remove plaintext passwords from Group Policy Objects (GPOs).
  - Implement Group Managed Service Accounts (gMSAs) for privileged access.
  - Use Local Administrator Password Solution (LAPS) for local admin accounts.
  - Conduct regular audits of GPOs for credential exposure.
- **Justification and explanation :**
  - GPP-stored passwords can be easily decrypted, leading to privilege escalation

and domain compromise. This is a high-risk vulnerability as it exposes sensitive credentials across the enterprise.

- **Additional notes and observations**

- Group Policy Preferences are used by IT admins to automate settings across all company computers like mapping drives, setting up printers, or creating user accounts.
- 

### Vulnerability #3

- **Title: IPv6 Network Poisoning**

- **Priority: 3**

- **Remediation action :**

- Disable IPv6 where it is not required.
- Enable Router Advertisement (RA) Guard on network switches.
- Deploy IPv6 monitoring tools to detect rogue router advertisements.

- **Justification and explanation :**

- IPv6 poisoning allows attackers to intercept network traffic, leading to data breaches. Given the critical CVSS score (9.8), this vulnerability requires immediate mitigation to prevent MITM attacks.
- 

### Vulnerability #4

- **Title: LLMNR & NBT-NS Poisoning**

- **Priority: 4**

- **Remediation action :**

- Disable LLMNR & NBT-NS via Group Policy.
- Strengthen DNS infrastructure to reduce fallback dependencies.
- Educate employees on phishing tactics exploiting name resolution attacks.

- **Justification and explanation :**

- Attackers can use LLMNR/NBT-NS poisoning to capture hashed credentials, enabling cross movement within the network. Disabling these legacy protocols closes a major security gap while Packet sniffing ya network listening.

- **Additional notes and observations**

- Local Multicast Name Resolution & NetBIOS Name Service is when it's ON in the system, the system can broadcast it throughout the network if it doesn't get any response from DNS as first due to spelling mistake or any other trigger.
-

## Vulnerability #5

- **Title: Kerberoastable Users**
  - **Priority: 5**
  - **Remediation action :**
    - Enforce strong password policies for service accounts.
    - Implement Managed Service Accounts (MSAs/gMSAs).
    - Regularly audit service accounts with SPNs.
    - Monitor for unusual Kerberos ticket requests.
  - **Justification and explanation :**
    - Kerberoasting allows attackers to crack service account passwords offline, leading to privilege escalation. Since one affected account in the audit was a Domain Admin, this is a high-impact risk.
  - **Additional notes and observations**
    - Single -sign-on (once logged in you get a token, and you can use printer, email and services etc.
    - Login → Ticket → Access → Crack → Attack
- 

## Vulnerability #6

- **Title: ASREP-Roastable Users**
  - **Priority: 6**
  - **Remediation action :**
    - Ensure Kerberos pre-authentication is enforced for all user accounts (Turn ON pre-authentication for every account (so they can't get the password response easily).
    - Audit for weak passwords — make users create stronger ones.
    - Set lockout rules — if someone guesses the wrong password too many times, lock the account.
  - **Justification and explanation :**
    - This is a stealthy attack method that must be prevented.
    - Some user accounts don't require Kerberos pre-authentication (a security check before login). This lets an attacker ask for a special login response from the server (called ASREP). The server sends it — encrypted with the user's password. The attacker then brute-forces (guesses) the password offline, without being detected.
  - **Additional notes and observations**
    - Authentication Service Response (ASREP)
    - Roastable : Which can be cracked offline
-

## Vulnerability #7

- **Title: Machines using SMBv1**
  - **Priority: 7**
  - **Remediation action :**
    - Disable SMBv1 across the enterprise via Group Policy (a tool to manage settings across many computers)
    - Update or replace old apps that still need SMBv1 to work.
    - Regularly check to make sure SMBv1 is still turned off in the future.
    - Keep the backup of the data as a precautionary measure if you still have systems with SMBv1.
  - **Justification and explanation :**
    - SMBv1 is highly exploitable (e.g., EternalBlue, WannaCry), making it a known risk. Disabling it significantly reduces ransomware exposure.
  - **Additional notes and observations**
    - Server Message Block version 1 is like a protocol used in organization computers to share files, printers, and data over a network. It was created in the 1980s and is outdated and insecure today.
    - Hacker can use Eternalblue – Hacking tool to rapidly spread the virus across unpatched or outdated computers.
- 

## Vulnerability #8

- **Title: Sensitive Information Stored in Network Shares**
  - **Priority: 8**
  - **Remediation action :**
    - Identify and remove plaintext credentials and unencrypted private keys.
    - Implement role-based access controls (RBAC) - only the right people can see certain folders.
    - Encrypt important data and use a password vault to store credentials safely.
    - Conduct regular audits of shared folders.
  - **Justification and explanation :**
    - Storing passwords and sensitive data in network shares is a severe security risk that could lead to intellectual property theft and regulatory violations.
  - **Additional notes and observations :**
    - A network share is a folder on one computer that others in the company can access over the network. It's often used for team documents or project files.
    - If people save sensitive information like passwords or private keys without proper encryption, it can create a huge risk.
-

## Conclusion

Addressing these vulnerabilities will significantly enhance OpenPharma's security posture by mitigating critical threats, ensuring compliance, and protecting intellectual property. This action plan follows CIS Controls recommendations and strengthens Active Directory security, network segmentation, and access controls. Immediate remediation is recommended for high-risk vulnerabilities to prevent exploitation and data breaches.

Next Steps:

- Obtain management approval for the remediation strategy.
  - Allocate resources and timelines for implementation.
  - Conduct follow-up audits to measure remediation success and adapt security measures as needed.
-